

Type of Policy Administrative

Effective Date January 2017

Last Revised March 2020

Review Date November 2026

Policy Owner ACME Corporation CyberSecurity

Contact Name John Kasket

Contact Title Governance Risk & Compliance Manager - Cyber Security

Contact Email johnkasket@acmecorp.com

Reason for Policy

This policy establishes the minimum requirements for generating and managing ACME Corporation user passwords, or other authentication factors, used by operating systems, applications, databases, and network devices owned by or managed by ACME Corporation. The intent of this policy is to protect access to Sensitive Data and ACME Corporation systems and networks.

Policy Statement

Single factor authentication (i.e. password authentication) or multifactor authentication (i.e. password and token) must be used to authenticate to any system or application which requires unique logon as defined by the Data Access Policy and Data Protection Safeguards Standard. The standards for single factor password authentication and multifactor authentication are defined in the standards section below

ACME Corporation account users must take all reasonable measures to protect their passwords and accounts. ACME Corporation users must never share their account passwords with anyone, including third-party service providers (e.g. Google). Each user is accountable and responsible for any action taken with that user's account and password. If there is a business need to share access to an account, such sharing should be accomplished through system permission delegation.

Exceptions to the requirements of this policy may be requested per the Policy Exceptions policy.

Standards: General Standards

- ACME Corporation user account passwords must never be transmitted over the network in a clear text format.
- Passwords must be protected at all times, and measures must be taken to prevent disclosure to any unauthorized person or entity.

- Passwords must be protected during distribution to the end user.
- Temporary passwords must be changed within 24 hours of creation.
- Default passwords for new servers, endpoints, and applications must be changed.

Single Factor Password Configuration Standards

Single factor passwords must:

- Contain at least 12 characters
- Contain characters from all four of the following character categories.
 - o Upper case alphabetic (e.g. A-Z)
 - o Lower case alphabetic (e.g. a-z)
 - o Numeric (e.g. 0-9)
 - o Special characters (e.g. ., !@#\$%~)
- Expire every 3 months
- Be different from the last 2 passwords selected

Multifactor Password Configuration Standards

When logging into systems or applications that require multifactor authentication, the associated password must:

- Contain at least 8 characters

Contain characters from all four of the following character categories.

- o Upper case alphabetic (e.g. A-Z)
- o Lower case alphabetic (e.g. a-z)
- o Numeric (e.g. 0-9)
- o Special characters (e.g. ., !@#\$%~)
- Expire every 3 months
- Be different from the last two passwords selected

The requirements for a multifactor password are lower than that of a single factor password. Single factor passwords lack a second form of authentication.

Mobile Device Pin/Password Configuration Standards

When using a mobile device, such as a smartphone or tablet, that requires authentication, the associated password/pin must:

- Contain at least 6 characters, or
- Leverage some other form of authentication such as
 - o Biometrics (e.g. facial recognition or thumbprint)
 - o Pattern code
 - o Swipe code

Scope

This Corporation-wide policy applies to any endpoint, mobile device, or application which requires unique logon as defined by the Data Access Policy and Data Protection Safeguards Standard, as well as all users of those systems.

Policy Terms

- Endpoint - Desktop computers, laptop computers, workstations, group access workstations, USB drives, small servers, cloud-hosted virtual machines, and personal Network Attached Storage (NAS)
- Mobile Device - Mobile devices at ACME Corporation include, but are not limited to:
 - o Cellular telephones
 - o Smartphones (e.g. iPhones, Android Phones, BlackBerrys)
 - o Tablet computers (e.g. iPad, Kindle, Kindle Fire, Android Tablets)
 - o Wearable Devices (e.g. Google Glass, watch devices)
 - o Personal Digital Assistants
 - o Any other mobile device containing ACME Corporation data (e.g. handheld scanning devices)
- Multifactor Authentication – A process for securing access to a given system, such as a network or website, that identifies the party requesting access through several categories of credentials (e.g. password and soft token or password and thumbprint).
- Server - Any computer system that hosts a campus unit or Corporation-wide service or acts as an authoritative source of data for the Corporation or campus unit.
- Single Factor Authentication - A process for securing access to a given system, such as a network or website, that identifies the party requesting access through only one category of credentials (e.g. password).

Enforcement

Violations of this policy may result in loss of ACME Corporation system and network usage privileges, disciplinary action, up to and including termination or expulsion as outlined in applicable ACME Corporation Employment policies and the ACME Corporation Student Code of Conduct, as well as personal civil and/or criminal liability.